

UBNetDefF25

Pentesting Lab

Ethan Messer

Mgs 427

K.Cleary

11/30/25

Table of contents

Contents

Executive Summary	3
Scope.....	4
Methodology	4
Technical Findings	5
Mitigation.....	10
Informational report.....	11
Work Cited	12
Appendix.....	13

Executive Summary

On November 30, 2025, UBNetDef performed a black box penetration test on a new social media server hosted on the ServerNet interface through the Kali environment. The purpose of this assessment was to identify vulnerabilities affecting the confidentiality, integrity, and availability of the system and to document the results of all scans performed during testing. The assessment identified eight vulnerabilities: three critical, one high-risk, two medium-risk, and two low-risk issues.

Critical	High	Medium	Low
- Anonymous FTP Access - Misconfigured Sudoers - Full Root Priv Escalation	- Multiple Services Exposed	- Web Server Exposure - Unauthorized User Access	- Reverse Shell Listener - Interface Enumeration

These findings indicate that attackers could gain unauthorized access, escalate privileges to root, obtain sensitive files through anonymous FTP, and exploit exposed services. Immediate remediation is required to reduce the risk of full system compromise and strengthen the server's overall security posture.

Scope

UBNetDef has conducted penetration test on a new social media server, within the ServerNet VM. By identifying and reporting a new possible vulnerabilities on the system. UBNetDef has minimized the impact on the integrity and confidentiality. The Penetration test was done on the Kali Server through the ServerNet VM on December 1st, 2025.

Methodology

The penetration test followed guidelines that are based on the 3 by 3 risk matrix, which is used to rate vulnerabilities through the likelihood can of the impact levels. Low risks are not a major problem for us, but can still be exploited to some extent.

	Low Impact	Medium Impact	High Impact
High Likelihood	Medium	High	Critical
Medium Likelihood	Low	Medium	High
Low Likelihood	Low	Low	Medium

Severity Levels:

Low – Vulnerabilities can be exploited by attackers or insider but only leads to minimal impact (ex, little information loss)

Medium – Vulnerabilities can be exploited with attackers or insider threats with medium effort and lead to moderate impact (ex, limited access, DDos attacks)

High – Vulnerabilities can be exploited by attackers or inside threats very easy and can lead to major problems (ex, business downtime)

Technical Findings

Finding #1 – Interface Enumeration Reveals Active Network Configuration

```
---(sysadmin@kali)-[~]
_-$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether bc:24:11:1c:bb:e1 brd ff:ff:ff:ff:ff:ff
    inet 192.168.15.140/20 brd 192.168.15.255 scope global dynamic noprefixroute eth0
        valid_lft 5705sec preferred_lft 5705sec
    inet6 fe80::bc24:11ff:fe1c:bbe1/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figure 1 Knowing the machine's assigned IP address allows an attacker to accurately determine the reachable subnet, and to possibly identify targets within.

The ip a command was executed to show the active network interfaces.

Finding #2 – Multiple Services Exposed with Version Disclosure

```
---(sysadmin@kali)-[~]
_-$ nmap -sv 10.43.22.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-01 15:53 EST
Nmap scan report for 10.43.22.1
Host is up (0.0014s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 10.43.22.7
Host is up (0.0015s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 10.43.22.20
Host is up (0.0020s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 10.43.22.30
Host is up (0.0020s latency).
Not shown: 998 filtered tcp ports (no-response), 11 filtered tcp ports (admin-prohibited)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.0 (protocol 2.0)
3306/tcp  open  mysql    MariaDB 5.5.5-10.3.39
4090/tcp  closed zeus-admin

Nmap scan report for 10.43.22.99
Host is up (0.0024s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
443/tcp   open  ssl/http Apache httpd 2.4.58 ((Ubuntu))
4800/tcp  open  ftp      vsftpd 3.0.5
Service Info: OS: Unix

service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (5 hosts up) scanned in 31.67 seconds
```

Figure 2 Exposed services significantly can increase the possibility of an attack. This shows I am vulnerable of an attack.

An Nmap service and version scan (nmap -sV -p- 10.43.22.0/24) identified many different host exposing network services, including OpenSSH, Apache, HTTPD, and Mysql. This scan also shows detailed software version, which shows OpenSSH, Apache, and MariaDB.

Finding #3 – Apache Web Server Exposed on Multiple Host (Medium Severity)

```
(sysadmin@kali) ~$ nmap -sV 10.43.22.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-01 15:53 EST
Nmap scan report for 10.43.22.1
Host is up (0.0014s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain (generic dns response: REFUSED)
80/tcp    open  http   nginx
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:V=7.95%I=7%D=12/1%Time=692E005A%P=x86_64-pc-linux-gnu%r(DNSV
SF:ersionBindReqTCP,E,"0x0c0x06x81x050x000x000x000");

Nmap scan report for 10.43.22.7
Host is up (0.0015s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh    OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http   Apache httpd 2.4.58 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 10.43.22.20
Host is up (0.0020s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh    OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http   Apache httpd 2.4.58 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 10.43.22.30
Host is up (0.0020s latency).
Not shown: 986 filtered tcp ports (no-response), 11 filtered tcp ports (admin-prohibited)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh    OpenSSH 8.0 (protocol 2.0)
3306/tcp  open  mysql  MariaDB 5.5.5-10.3.39
9090/tcp  closed zeus-admin
```

Figure 3 An exposed Apache web sever can potentially exploitation of vulnerable modules or unpatched CVEs, Directory enumeration and sensitive file disclosure, and Attackers identifying different services and targeting specific vulnerabilities.

The nmap scan (nmap -sV 10.43.22.0/24) identified multiple Linux hosts running an exposed Apache HTTPD web server. This also shows additional information including SSL key fingerprints and explains the default Ubuntu Web Server configuration.

Finding #4 – Anonymous FTP Access Exposes Sensitive Files (Critical Severity)

```
Session Actions Edit View Help
/:
PHPSESSID:
- httponly flag not set
ssl-cert: Subject: commonName=yourdomain.com
Not valid before: 2025-04-17T04:05:11
Not valid after: 2026-04-17T04:05:11
220/tcp open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.11 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:
- 256 94:61:85:ae:4c:7d:c0:e8:57:de:ea:8c:b6:5e:c7:15 (ECDSA)
- 256 4d:73:19:fe:b2:b1:51:46:fc:cb:95:86:89:ca:71:15 (ED25519)
000/tcp open  ftp      vsftpd 3.0.5
ftp-anon: Anonymous FTP login allowed (FTP code 230)
-rw-r--r--  1 0      0      228 Apr 16  2025 FTPServerUsage.txt
-rw-r--r--  1 0      0      183 Apr 16  2025 TestCreds.txt
-rw-r--r--  1 0      0      3381 Apr 16  2025 id_rsa
ftp-syst:
STAT:
FTP server status:
Connected to ::ffff:192.168.15.140
Logged in as ftp
TYPE: ASCII
No session bandwidth limit
Session timeout in seconds is 300
Control connection is plain text
Data connections will be plain text
At session startup, client count was 1
vsFTPD 3.0.5 - secure, fast, stable
_End of status
service Info: OSs: Linux, Unix; CPE: cpe:/o:linux:linux_kernel

Post-scan script results:
ssh-hostkey: Possible duplicate hosts
Key 256 20:68:54:26:ca:f2:a9:61:1e:95:47:03:16:b3:c9:35 (ECDSA) used by:
10.43.22.7
10.43.22.20
Key 256 8d:69:6f:89:41:e3:9c:8d:c3:65:39:05:fb:2a:d9:a7 (ED25519) used by:
10.43.22.7
10.43.22.20
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (5 hosts up) scanned in 290.40 seconds

--(sysadmin@kali)-[~]
```

Figure 4 If an attacker downloads the exposed `id_rsa` file, they can potentially attempt: Direct SSH authentication into another server, Lateral movement across the environment networks, privileged escalation using different credentials stored in `TestCreds.txt`, and accessing sensitive operational documentation (`FTPServerUsage.txt`)

The service scan identified an FTP server (vsftpd 3.0.5) on host 10.43.22.140 that allows anonymous login without authentication. After logging in anonymously, multiple different files with available including `FTPServerUsage.txt`, `TestCreds.txt`, and `id_rsa` (SSH private Key)

Finding #5 - Unauthorized User Level Access (Medium Severity)

```
(sysadmin@kali)~$ whoami
sysadmin

(sysadmin@kali)~$ hostname
kali

(sysadmin@kali)~$ pwd
/home/sysadmin
```

Figure 5 Unauthorized user-level access provides attackers with the ability: Read and modify the user files, Could potentially move to other systems, and Escalate privileges using local misconfigurations.

During the testing, the attacker will successfully gain shell access as the sysadmin user on the Kali system, he will run the commands such as whoami, hostname, and pwd, which will confirm that the account is compromised and the attacker had interactive access to the user's home directory.

Finding #6 - Full report access allowed to sysadmin (Critical Severity)

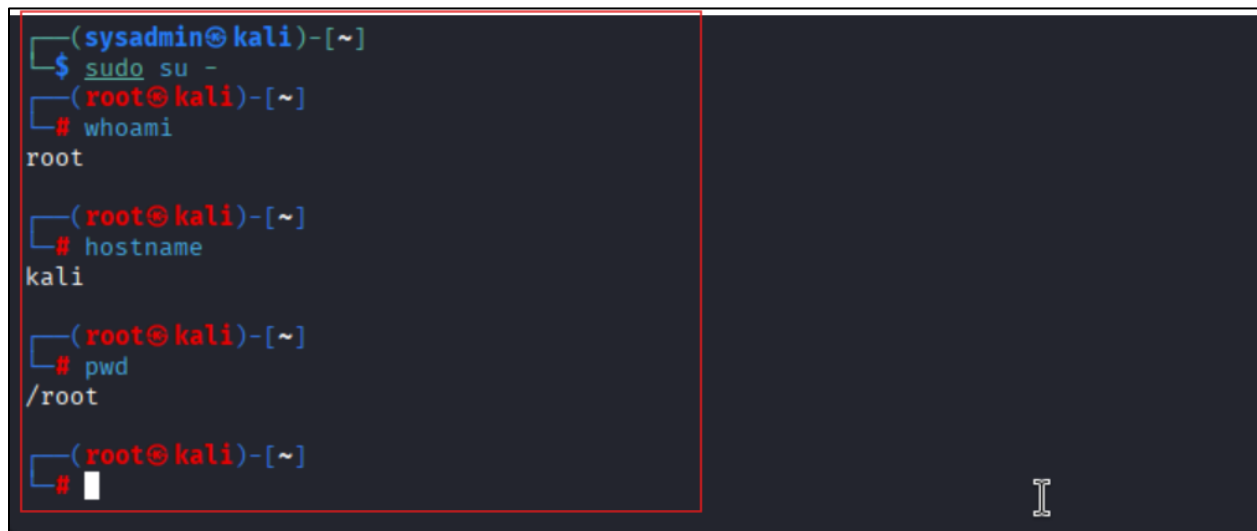
```
(sysadmin@kali)~$ sudo -l
[sudo] password for sysadmin:
Matching Defaults entries for sysadmin on kali:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User sysadmin may run the following commands on kali:
    (ALL : ALL) ALL
```

Figure 6 this means sysadmin can run any command as any user, including a root. This is a critical privilege escalation flaw. (allowing an attacker to fully compromise the system state)

The file /etc/sudoers is misconfigured, allowing the unprivileged user account sysadmin to run any command as any user without restriction shown below:

Finding #7 – Full Root Privilege Escalation (Critical Severity)



```
(sysadmin@kali)-[~]
$ sudo su -
(root@kali)-[~]
# whoami
root

(root@kali)-[~]
# hostname
kali

(root@kali)-[~]
# pwd
/root

(root@kali)-[~]
#
```

Figure 7 This confirms that an attacker using the sysadmin account can obtain full administrative control over the target system

Figure

The sysadmin account has unrestricted sudo access, allowing it to escalate privileges to the root user without constraints. This was verified by executing the commands see above.

Finding #8 – Authorized Listener Open on High Port (Low Severity)



```
(sysadmin@kali)-[~]
$ nc -lnvp 8888
listening on [any] 8888 ...
```

Figure 8 Screenshot of Reverse Shell Access

To mitigate reverse shell attacks, there are multiple recommendations to conducting vulnerability scans and keeping secure, encrypted passwords. According to TechTarget, vulnerability scans are crucial for system state functionality since it "reveals open ports in network infrastructure." Ports that are unidentified and suspicious should be investigated immediately and closed off to prevent damage.

Mitigation

Finding #1 – Interface Enumeration Reveals Active Network Configuration Mitigation: Limit the interface details from unauthenticated users by restricting system-level commands and hardening local access controls.

Finding #2 – Multiple Services Exposed with Version Disclosure Mitigation: Disable the unnecessary services and then restrict service exposure using firewall rules.

Finding #3 – Apache Web Server Exposed on Multiple Hosts (Medium Severity) Mitigation: Harden the Apache configuration by disabling directory listing, removing default pages, and applying current security patches.

Finding #4 – Anonymous FTP Access Exposes Sensitive Files (Critical Severity) Mitigation: Disable anonymous FTP access immediately and require authenticated, encrypted connections only. Then remove all the sensitive files from the FTP directory and replace FTP with a secure alternative such as SFTP.

Finding #5 – Unauthorized User-Level Access (Medium Severity) Mitigation: Enforce a stronger authentication controls, which will be including password complexity and account restrictions. Audit user accounts regularly and remove the unnecessary or unused access privileges.

Finding #6 – Misconfigured Sudoers File Allows sysadmin Full Access (Critical Severity) Mitigation: Correct the /etc/sudoers configuration to limit sysadmin to only approved administrative commands. Apply the principle of least privilege and use role-based access control to prevent unintended privilege escalation.

Finding #7 – Full Root Privilege Escalation (Critical Severity) Mitigation: Remove all the unrestricted sudo access from non-administrative accounts and monitor privileged command use. Then Implement logging and alerts for privilege escalation attempts to possibly detect misuse quickly and solve issue.

Finding #8 – Unauthorized Listener on High Port (Low Severity) Mitigation: Restrict the outbound listeners and high-port activity using firewall rules and system permissions. Then monitor for abnormal network behavior and close the unused ports to reduce possible opportunities for reverse shell attacks.

Informational report

This report follows the structure of UBNetDef Informational Report Style Guide and separates the non-technical and technical requirements. All findings were written in original wording, with proper citations used when referring to external information. Screenshots were formatted with figure labels and details underneath as a description describing what the image above is. The screenshots are placed in the appendix in accordance with UBNetDef standards for this report..

Citation and paraphrasing guidelines were followed to avoid plagiarism, and the report uses a clear structure and proper section formatting. This submission reflects the required informational reporting in the requirements for this assignment.

Work Cited

Gruber, Dave. "Change Is in the Wind for SecOps: Are You Ready?" *SearchSecurity*, 24 Apr. 2025, www.techtarget.com/searchsecurity/opinion/Change-is-in-the-wind-for-SecOps-Are-you-ready.

Syaputra, M. "100 Linux Commands to Perform Penetration Testing." *Medium*, 20 June 2023, medium.com/@msyaputra/100-linux-commands-to-perform-penetration-testing-93f67cf3dada.

Appendix

Finding #1 – Interface Enumeration Reveals Active Network Configuration.....	5
Finding #2 – Multiple Services Exposed with Version Disclosure	5
Finding #3 – Apache Web Server Exposed on Multiple Host (Medium Severity).....	6
Finding #4 – Anonymous FTP Access Exposes Sensitive Files (Critical Severity)	7
Finding #5 - Unauthorized User Level Access (Medium Severity).....	8
Finding #6 - Full report access allowed to sysadmin (Critical Severity).....	8
Finding #7 – Full Root Privilege Escalation (Critical Severity).....	9
Finding #8 – Authorized Listener Open on High Port (Low Severity)	9